

TD02 — Modèle de menace du checkout ShopLab

Séance S04 · 90 min · C01, C04 · Groupes de 3–4

Situation

Le nouveau checkout reçoit un panier JSON, lit le prix produit en base, appelle un simulateur de livraison interne, crée la commande et émet un reçu. Le navigateur conserve une session cookie. L'équipe propose aussi un champ `callback_url`. Tout est encore local et synthétique.

Actifs et contraintes imposées

Actifs candidats : identité/session, prix, commande, disponibilité, preuve d'achat, journal d'audit.
Frontières minimales : navigateur non fiable, proxy edge, API, DB interne, service livraison. Les tests offensifs doivent rester dans ShopLab; le callback réel est remplacé par `/api/url-check` sans fetch.

Atelier

1. **Inventaire (10 min)**. Priorisez cinq actifs selon confidentialité/intégrité/disponibilité et justifiez le premier.
2. **DFD (20 min)**. Dessinez processus, magasins, flux bidirectionnels, protocoles et frontières. Marquez données contrôlées par le client.
3. **Abus (20 min)**. Produisez six scénarios distincts couvrant au moins : BOLA, modification de prix/mass assignment, CSRF, SSRF, rejeu de session et indisponibilité. Format : précondition → action → impact.
4. **Contrôles (15 min)**. Pour chaque scénario, choisissez contrôle préventif, détectif et test de vérification. Placez le contrôle au composant responsable.
5. **Priorisation (15 min)**. Notez vraisemblance et impact sur 1–4, calculez le score, puis ajustez une priorité avec une justification métier. La matrice ne remplace pas le raisonnement.
6. **Scope (10 min)**. Rédigez règles d'engagement, stop conditions, preuves autorisées et éléments explicitement hors scope.

Livrable et barème /20

Un DFD lisible, registre de six menaces et plan de tests local. Aucune solution technique n'est acceptée sans menace liée et résultat observable.

Axe	Insuffisant	Conforme	Maîtrisé	Pts
DFD	composants sans flux	flux/frontières complets	confiance explicitée	5
Scénarios	noms OWASP	précondition/action/impact	diversité et chaîne d'abus	6
Contrôles/tests	checklist	contrôle au bon niveau	prévention+détection+retest	6
Scope	absent	local/stop/preuves	limites argumentées	3